

Risk Management Project

GRC Analyst: Nyerovwo Obarueroro

Date: July 17, 2026

Executive Summary

This risk management project aims to identify, assess and prioritize risk, and also provide ways to manage the risk that could impact Meridian Charity's Operations, their information assets, and ability to deliver its services effectively in compliance with the regulatory requirement.

The assessments are focused on understanding the organization's assets, its classification, potential threats and vulnerabilities that could affect the confidentiality, integrity and availability of these assets. This project follows an organized risk management approach, by identifying assets, assessing the risk, analyzing the likelihood and impact, documenting the findings within a risk register and implementing the appropriate controls.

The objective of this project is to help the Meridian Charity manage risk, while protecting sensitive data and also strengthen its risk posture to ensure the continued delivery of safe and reliable services to its beneficiaries and stakeholders.

Organisation Background

Meridian Charity is a charitable organization that provides support to people who are vulnerable, going through mental health issues, or struggling with bereavement. The Charity is based in Ashfield, England and was established in 2018 and offered its support during Covid 19, which left many people vulnerable. The organization's mission is to support and safeguard members of the community. The Charity provides emotional support, funeral assistance and community services like workshops and events.

Risk management is important because the charity handles sensitive information of vulnerable people and effective risk management will help protect this confidential information, ensure safeguarding responsibilities are maintained and risk such as data breaches, fraud and operational disruption is reduced. This will help maintain governance and trust with beneficiaries, donors, regulators and the wider community.

Risk Management Policy - Find attached the risk management policy

Risk Management Methodology

The risk management methodology describes the way Meridian Charity manages Risk.

Understanding the internal and external context of the organisation establishes the foundation of risk management. ISO 31000 mandates defining the context as risk is relative. It determines the risk the charity faces, how severe it is and if the charity can absorb the risk. Without defining this environment, business cannot effectively align their strategic goals.

External Context: are those factors or conditions which are outside of the Charity's control but dictates the business environment.

Internal Context: are those conditions that are within the charity itself and they define the risk the charity generates and its ability to tolerate them.

Step 1 Risk Assessment

Risk assessment is the process of identifying risk, analyzing how likely they are to happen and the consequences or impact they could have on an organization.

1.1 Identify Assets

An asset is anything that has actual or potential value to an organization.

Take inventory of Meridian Charity's asset which include primary asset and supporting asset. Assets should be classified and assigned to their various owners.

1				
2				
3				
4				
5				
6	Asset ID	Asset Name	Asset Owner	Asset classification
7	A001	Website	IT Manager	Public
8	A002	Donor Information	Fundraising Manager	Confidential
9	A003	Volunteer records	Volunteer Coordinator	Confidential
10	A004	Beneficiary data	Safeguard Lead	Highly confidential
11	A005	Safe guarding records	Safeguard lead	Highly Confidential
12	A006	Social media accounts	IT Manager	Public
13	A007	Financial records	Finance Manager	Confidential
14	A008	Email system	IT Manager	Internal
15	A009	Microsoft 365/ Google workspace	IT Manager	Internal
16	A010	Staff laptops	IT Manager	Internal
17	A011	Mobile Phones	IT Manager	Internal
18	A012	Office Building	Facilities Manager	Internal
19	A013	Backup data	IT Manager	Highly confidential
20	A014	Online Donation Platform	Fundraising Manager	Confidential
21	A015	Policies and Procedures	Board of Trustees	Internal
22				
23				
24				
25				

Image 1

1.2 Risk Identification and Analysis

The purpose of risk identification exercise is to identify those uncertainties that could prevent Meridian Charity from achieving their objectives.

For Meridian Charity, this involves looking at its various assets, identifying vulnerabilities and possible threats that could exploit those vulnerabilities and their possible impact on the organisation.

Identified risks were analysed using two main factors:

Likelihood – The probability of a risk occurring. This was assessed using a scale from 1 to 5 (Rare, Unlikely, Possible, likely and Certain).

Impact – The potential effect or consequences on the Charity if the risk occurs. This could be consequences such as financial loss, harm to beneficiaries, legal consequences, disruption to operations and reputational damage. Impact was assessed using a scale from 1 to 5 (Very Low, Low, Moderate, High and Severe)

The Overall risk rating was calculated by multiplying likelihood by impact

Risk Score = Likelihood x Impact

Using a 5 x 5 matrix the risk score would range from 1 to 25

Impact	Likelihood				
	1 Rare	2 Unlikely	3 Possible	4 Likely	5 Certain
5 Severe	5	10	15	20	25
4 High	4	8	12	16	20
3 Moderate	3	6	9	12	15
2 Low	2	4	6	8	10
1 Very Low	1	2	3	4	5

Image 1.2 - Risk Matrix

The results of this analysis will be recorded in the risk register and each risk will be assigned a risk owner. The risk owner is someone with the authority to manage the risk and implement appropriate controls.

The risk score will be on a scale from 1(Low Risk) to 25 (Highest Risk). This score will be used to evaluate and prioritize risks.

1.3 Risk Evaluation

The risk score is compared against Meridian Charitys Risk acceptance criteria (or risk appetite) to decide whether the risk is acceptable or needs treatment.

Based on the comparison, each risk is categorized in one of the four categories (Low, medium, High, Very High). Risk that are withing Meridian charity's risk acceptance criteria can be accepted and do not require further treatment. Risk that are not with the risk acceptance criteria will need to undergo treatment.

1.4 Risk Acceptance Criteria /Risk Appetite

Meridian Charity's supports vulnerable people and handles sensitive information so it has low risk appetite in areas that could affect safeguarding, beneficiary data and welfare, data protection and legal compliance, financial integrity and the charity's reputation. Risk assessed as high or very High exceed the charity's risk acceptance criteria and must be treated to reduce the level of risk.

Low and Medium risk may be accepted where necessary controls are in place and are subject to regular monitoring.

Risk Level/Score	Acceptance Criteria	Action
Severe (15 -25)	Unacceptable	Immediate action is required for mitigation
High Risk (10 -14)	Not acceptable	Risk Treatment is required to reduce the potential likelihood or impact
Medium Risk (5 – 9)	Tolerate	Risk is monitored and action to reduce risk where necessary is considered.
Low Risk (1 – 4)	Acceptable	The risk is accepted and monitored

Step 2 Risk Register

The Risk Register is a core component of the Risk Management process. It provides a structured record of all identified risk that may affect the confidentiality, integrity and availability of Meridian Charity's assets. A Risk Register is essential because it supports informed decision-making allowing Board of Trustees to prioritize risks based on likelihood and impact, ensuring resources are allocated efficiently.

Step 3 Risk Response

There are four ways which Meridian Charity can respond to risk, these are:

- 1 Treat
- 2 Tolerate
- 3 Transfer
- 4 Terminate

Meridian Charity has decided to manage the risk by treating it. The purpose of treating the risk is to ensure the charity operations are continued while risk is reduced to a lower or more acceptable level.

3.1 Risk Treatment Plan

A risk treatment plan is developed and logged in the risk register, controls are implemented and the strength of the controls are subtracted from the baseline risk score to achieve the residual risk score. The residual impact and residual likelihood score is reduced which leads to a reduction in the residual risk. If the residual risk is still above the risk acceptance criteria, decisions would be made to implement more controls to bring the risk to an acceptable level. Target due dates for fixing the risk are assigned and if it extends, written explanations or reasons should be attached to enable the auditor have a clear reason for the delay.

4. Monitor, Review, and Communicate

Risk management is a continuous process and not a onetime project.

4.1 Monitor

Controls are monitored to verify their day to day working and the effectiveness of the controls. As stated in the risk treatment plan, the status of risk treatment should be reviewed weekly, and if an owner misses a target due date, log the reason immediately. The IT team can also run a monthly report to show that controls on laptops, and backups are effective and are successfully completed without error.

4.2 Review

The charity's risk register would be reviewed periodically; a schedule would be set every three months to actively pull down and restore a sample of donor database file to see if it works.

If the charity adopts a new online donation platform, or change the office building, the risk register should be open and updated.

4.3 Communicate

Communication ensures that everyone (from entry level volunteer to Board of Trustees) understand their security responsibilities and the charity's risk profile.